



APPALACHIAN VALLEY MEDICAL CENTER

Access Control Policy

AVMC Information Technology & Security

Policy Owner	AVMC Information Technology and Security
Applies To	Workforce members, contractors, students, vendors, volunteers, systems, services, and authorized devices
Status	Approved/Final
Review Cycle	At least annually and after significant role, technology, operational, legal, or cybersecurity-risk changes

1. Purpose

The Appalachian Valley Medical Center (AVMC) Access Control Policy defines requirements for granting, managing, reviewing, and revoking access to AVMC systems, networks, applications, devices, facility technology, and information. Access shall be granted only for legitimate job or operational needs and limited by the principles of least privilege and separation of duties.

AVMC uses administrative and technical controls to prevent unauthorized access, restrict lateral movement, protect clinical and operational services, and maintain the confidentiality, integrity, and availability of organizational information.

2. Scope

This policy applies to all AVMC workforce members, contractors, students, vendors, volunteers, service accounts, connected devices, and other identities or systems that access AVMC resources.

Covered resources include clinical systems; the electronic health record (EHR); servers; administrative, imaging, laboratory, IT management, Facilities/BMS, and physical-security systems; medical IoT; guest wireless access; network infrastructure; and public-facing services; and backup and recovery infrastructure.

3. Access Control Principles

Access shall be expressly authorized for a defined business, clinical, technical, or operational need and limited to the minimum permissions required for assigned duties. Technical access alone does not constitute authorization.

When supported, AVMC shall assign unique identities to users and devices, protect credentials, limit shared accounts to technically necessary and formally approved cases, and review access when roles or responsibilities change. Privileged access shall be more restricted than standard access and used only for authorized administrative tasks.

4. Account and Credential Management

An appropriate manager, system owner, or AVMC IT/Security authority shall approve access requests before access is granted. Accounts and credentials shall be issued only to authorized users, services, and devices.

Users shall not share passwords or accounts. Access shall be updated or revoked when no longer needed, including upon termination, role change, contract completion, or loss of operational need. Default system and device credentials shall be changed when supported.

5. Network Segmentation and Least Privilege

AVMC shall use network segmentation and access controls to separate systems by operational purpose and trust level. Traffic between network zones shall be allowed only when required for authorized business or technical functions.

The AVMC lab design separates Administration, Clinical, Imaging/Laboratory, Medical IoT, Servers, IT Management, Guest, and Facilities/BMS functions into distinct network zones. Access-control lists (ACLs) enforce selected trust boundaries in addition to VLAN separation.

6. Guest Network Access

Guest and personal devices shall use the designated guest network. Guest systems may use required network services such as DHCP and DNS and may reach approved public resources, but they shall not access protected AVMC internal systems.

In the AVMC design, VLAN 70 is restricted from the internal 10.40.0.0/16 environment while retaining access to the simulated public AVMC website.

7. Medical IoT Access

Medical IoT devices shall access only the systems and services necessary for their clinical functions. They shall not have unrestricted access to AVMC's internal networks or the public Internet.

In the AVMC design, VLAN 40 permits devices to use required DNS services and access the EHR service over HTTPS, while blocking unrelated internal traffic and external Internet access. This applies least privilege at the service level rather than granting unrestricted destination access.

8. Facilities and Building Management Access

Facilities/BMS systems, physical-access devices, environmental controls, and security cameras shall be isolated from clinical resources and other networks unless a documented operational requirement exists.

In the AVMC design, VLAN 80 retains access to its local BMS/IoT management services and required DNS functions while routed access to clinical systems and the simulated Internet is denied.

9. Administrative and Privileged Access

Administrative privileges shall be granted only to personnel whose duties require them. Privileged accounts shall not be used for routine tasks when a standard account is adequate.

Only authorized IT/Security personnel shall modify routing, VLANs, ACLs, servers, security controls, or other critical infrastructure. Changes should be documented and validated after implementation.

10. Backup Infrastructure Access

AVMC backup and recovery infrastructure shall be protected as a separate security boundary. Access shall be limited to authorized IT/Security personnel and approved backup services, and shall use dedicated administrative or service credentials that are separate from routine production-domain and general administrative credentials.

Offline or logically isolated backup repositories shall remain inaccessible from production networks except during an authorized backup, verification, restoration, or testing activity. Where network connectivity is required to transfer backup data, AVMC shall use a documented, time-limited or otherwise tightly restricted access path that permits only the approved source, destination, protocol, and service necessary for the operation. The access path shall be disabled or returned to its isolated state when the authorized activity is complete.

Backup access controls shall follow least privilege and separation of duties. Access events and configuration changes affecting backup infrastructure should be logged and reviewed, and backup credentials shall be changed or secured immediately when compromise is suspected.

11. Access Review, Monitoring, and Enforcement

AVMC IT/Security and system owners shall periodically review permissions and remove access that is excessive, outdated, or no longer needed. They should also review access after role changes, departures, security incidents, or significant system changes.

AVMC may use logs, ACL hit counters, authentication records, system monitoring, and other technical evidence to confirm that access controls function as intended. Suspected unauthorized access shall be addressed under the AVMC Incident Response Policy.

12. Roles and Responsibilities

- All users: use access only for authorized duties, safeguard credentials, and report suspected unauthorized access.
- Managers and system owners: approve access based on job or operational needs and notify IT/Security when those needs change.
- AVMC IT/Security: maintain technical access controls, administer accounts and network restrictions, review access, monitor violations, and support incident response.
- AVMC leadership: approve access-control policy, support enforcement, and provide resources to manage cybersecurity risk.

13. NIST Cybersecurity Framework 2.0 Mapping

This policy primarily maps to the PROTECT and GOVERN Functions of the NIST Cybersecurity Framework (CSF) 2.0, with particular emphasis on Identity Management, Authentication, and Access Control (PR.AA).

CSF 2.0 Area	AVMC Policy Alignment	Application
PR.AA-01	Manages identities and credentials for authorized users, services, and hardware.	Sections 3-4, 9
PR.AA-03	Requires authentication of authorized users, services, and hardware.	Sections 3-4
PR.AA-05	Defines, manages, enforces, and reviews permissions using least privilege and separation of duties.	Sections 3, 5-11
PR.AA-06	Supports risk-based control of physical access through Facilities/BMS and physical-security systems.	Section 8
GV.PO	Establishes and communicates organizational cybersecurity policy requirements.	Sections 1-13
GV.RR	Assigns cybersecurity roles and	Section 12

responsibilities for access
decisions and enforcement.

References

National Institute of Standards and Technology. (2024). The NIST Cybersecurity Framework (CSF) 2.0. NIST CSWP 29. <https://doi.org/10.6028/NIST.CSWP.29>

SANS Institute. Security Policy Templates. <https://www.sans.org/information-security-policy>